SIMATS ENGINEERING

ETHICAL HACKING

ASSIGNMENT 2 – CO2

Footprinting, Reconnaissance and Social-Engineering Awareness

Course: ITA14 – Ethical Hacking

Assignment nature: Individual

Student Details	Information
Student Name	Balaji Rohith MV
Register Number	192521269
Department / Section	B.Tech Information Technology
Academic Year / Semester	2026
Faculty Name	Dr. Parthiban
Date of Submission	02.11.2026

Total Marks 50

Introduction and Scope

This report designs and evaluates authorized footprinting and reconnaissance workflows. It combines open-source information gathering, DNS analysis, competitive-intelligence awareness, data validation, hierarchical traversal and constrained reconnaissance. The work is limited to domains and systems explicitly owned by the assessor or covered by written authorization. Public information about real people is not collected for targeting, and no phishing, vishing, pretexting, tailgating

or other social-engineering activity is performed against real individuals.

The assignment's engineering sequence is: Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate. The report supplies reproducible methods, safe test cases, expected outcomes and evidence templates. Actual command outputs and measured timings are not represented as completed experiments because no authorized target outputs were provided.

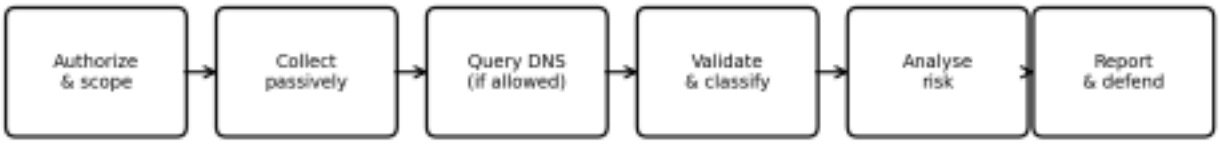


Figure 1. End-to-end authorized reconnaissance workflow.

Q1 – Evaluate and Engineer a Footprinting Strategy

1.1 Objectives and strategy

The objective is to build a multi-source view of an authorized domain without treating every discovered item as trustworthy or in scope. A source register is maintained for each observation: source, query, timestamp, returned value, scope status, confidence, corroborating source and action taken.

Technique	Classification	Purpose	Limit / control
WHOIS / RDAP lookup	Passive	Registrar, registration dates, nameservers and selected registration metadata.	Privacy redaction and stale records are possible; corroborate with DNS and authoritative sources.

Search-engine operators	Passive	Find indexed pages, public documents and exposed organizational references.	Indexing is incomplete and may be stale; record exact query and retrieval date.
Archived public pages	Passive	Understand historical public content and changes over time.	Archived content may no longer be current; label as historical.
DNS queries (A, MX, NS, TXT)	Usually passive with respect to the target service	Resolve published DNS records through recursive/authoritative DNS infrastructure.	Queries create DNS traffic and may be logged; stay within the approved query plan.
Direct service probing / enumeration	Active	Test a permitted host or service for directly observable exposure.	Requires explicit authorization and rate limits; omit if not in scope.

1.2 Ordered collection workflow

- Confirm written authorization, domain ownership, permitted techniques, dates, rate limits and exclusions.
- Normalize the approved root domain and create an allow-list of exact domains, subdomains and third-party services.
- Collect WHOIS/RDAP, indexed public pages and archived content first; preserve query strings, source and timestamps.
- Query only approved DNS names and record A, MX, NS and TXT responses with TTL and resolver details where available.
- Classify each item as in-scope verified, in-scope unverified, out-of-scope, personal data or historical.
- Corroborate important findings using an independent source; retain contradictions rather than silently choosing one.

- Summarize attack-surface implications and recommend defensive actions without attempting exploitation.

1.3 Safe command examples

The following commands are templates. Replace the example domain only with a domain explicitly authorized for the exercise. Do not run active enumeration against unrelated systems.

```
whois example.corp.example
nslookup -type=A example.corp.example
dig example.corp.example A
dig example.corp.example MX
dig example.corp.example NS
dig example.corp.example TXT
```

1.4 Four contrasting target profiles and predictions

Test profile	Prediction before collection	What to verify after collection	Likely interpretation
A. Well-protected domain	Limited registration detail; deliberate DNS records; few unnecessary public documents.	Confirm whether exposed records match the published service inventory; note privacy-redacted registration.	Low visible exposure does not prove absence of internal assets.

B. Information-leaking domain C. Misconfigured-DNS domain D. Minimal-public-footpr int domain	Public documents or archived pages may reveal technology, contact channels or naming conventions. Unexpected records, stale values or excessive disclosure may appear. Few indexed pages and limited DNS records beyond essential services.	Record each document URL, date, metadata category and whether the detail is still valid. Compare authoritative answers, TTLs and approved reference configuration; do not infer compromise from one response. Check multiple permitted sources before concluding that the footprint is minimal.	Public information can increase reconnaissance context; remove unnecessary metadata. Configuration hygiene and zone controls require review. Low visibility may reflect indexing limits, not necessarily strong security.

1.5 Evidence and source reliability

Evidence field	Example entry format
Target / scope	example.corp.example — approved root domain
Source and query	DNS resolver; dig example.corp.example MX
Collection time	YYYY-MM-DD HH:MM UTC
Observation	Paste exact returned record or document reference
Scope decision	In scope / out of scope / requires confirmation
Confidence	High / medium / low, with reason
Corroboration	Second independent source or 'not corroborated'
Disposition	Retain / re-query / reject / historical only

Reliability is assessed using authority, freshness, directness, reproducibility and corroboration. WHOIS privacy redaction is not evidence that a domain has no owner. Search results are discovery aids, not authoritative proof. Archived pages are historical. DNS answers can vary by resolver, cache, geography and split-horizon policy.

1.6 Changed condition: fifty subdomains and third-party services

The original manual strategy becomes inefficient at fifty subdomains. Keep the same authorization and validation principles, but introduce an approved asset inventory, automated read-only DNS queries, deduplication, rate limiting, per-source logs and exception review. Third-party services must be separately classified: a subdomain pointing to a SaaS provider does not automatically authorize testing that provider. The strategy remains suitable if scope is machine-readable, collection is rate-limited and third-party assets are excluded unless separately approved.

Q2 – Build a Reliable DNS Footprinting Workflow

2.1 DNS workflow

● Load the approved domain list and reject names outside the allow-list. ● Query A, MX, NS and TXT records using dig; use nslookup as an independent command-line cross-check where useful.

● Record answer, TTL, responding resolver, query time and DNS response status. ● Repeat selected queries against an approved authoritative nameserver to investigate discrepancies.

- Attempt AXFR only when written authorization explicitly names the authoritative server and permits zone-transfer testing.
- Compare results with the expected DNS inventory; classify stale, delegated, split-horizon and unexplained records.
- Recommend least-privilege zone-transfer settings and re-test only under the approved scope.

```
dig example.corp.example A
dig example.corp.example MX
```

```
dig example.corp.example NS
dig example.corp.example TXT
nslookup -type=MX example.corp.example
# AXFR: only with explicit written permission and named server
dig @<authorized-ns> example.corp.example AXFR
```

2.2 Record types

Record	Meaning	Assessment value
A	Maps a name to an IPv4 address.	Identifies published IPv4 endpoints; validate ownership and scope.
MX	Identifies mail exchangers and preference values.	Shows mail-routing providers and possible third-party dependencies.
NS	Identifies authoritative nameservers.	Reveals DNS delegation and the authoritative DNS provider.
TXT Publishes text data, often verification and email-security	policy. May show SPF, domain	verification or other operational
		metadata; avoid treating every TXT string as a secret.

2.3 Six contrasting DNS cases

Case	Predicted observation	Validation focus	Defensive conclusion
1. Correctly secured zone	Expected records; AXFR refused or restricted.	Compare with approved inventory; AXFR test only if permitted.	Restrict transfers to approved secondary servers.

2. Zone transfer allowed	AXFR may return many records if explicitly tested with permission.	Check whether the responding server is authoritative and the test is authorized.	Unrestricted transfer can disclose internal naming and asset relationships.
3. Stale record	A record may point to an old address or retired service.	Compare TTL, authoritative response and current asset owner confirmation.	Remove obsolete records and review dangling references.
4. Split-horizon DNS	Internal and external resolvers return different answers.	Record resolver location/type; compare only using approved resolvers.	Different views can be intentional; document expected policy.
5. Third-party delegation	NS records point to an external DNS provider.	Verify contractual ownership and whether provider testing is excluded.	Delegation is not permission to test the provider.
6. Inconsistent/cached answers	Resolvers may return different values or TTL states.	Repeat queries, inspect TTL and query authoritative server if allowed.	Do not report a single cached response as definitive.

2.4 Zone-transfer risk and countermeasures

A successful zone transfer can expose a structured list of hostnames and service relationships. This increases an assessor's knowledge of the organization's public naming structure, but it does not by itself demonstrate that the listed hosts are vulnerable. Risk depends on whether sensitive names or non-public infrastructure are exposed and whether those names are reachable.

● Allow AXFR only to explicitly configured secondary nameservers. ● Use TSIG to authenticate authorized zone-transfer peers where supported. ● Monitor and alert on unexpected transfer attempts.

- Review DNS delegation, stale records and split-horizon policy periodically.
- Retest only against the authorized nameserver and preserve evidence of the response.

After a countermeasure is applied, the expected result is that an unauthorized transfer is refused while legitimate secondary replication continues. Actual before-and-after outputs must be attached from the lab.

Q3 – Create a Competitive-Intelligence Awareness Utility

3.1 Utility architecture

The utility collects public organizational information for defensive awareness, not for targeting people. It stores source provenance and maps business information to potential human-risk scenarios and corresponding warning indicators.

Module	Input / action	Output
Source registry	Approved organization, public source categories and search operators.	Scope-controlled source list.
Collection planner	Job advertisements, annual reports, press releases and public organizational profiles.	Documented queries and collection log.
Evidence store	URL, title, date, excerpt/category and retrieval timestamp.	Traceable evidence records.
Risk mapper	Map organizational information categories to phishing, vishing, pretexting or tailgating scenarios.	Human-risk explanation and warning indicators.
Countermeasure recommender	Awareness controls and verification procedures.	Training recommendations and review checklist.

3.2 Search operators and documented procedure

Operator	Illustrative query pattern	Use
site:	site:corp.example careers	Restrict discovery to a public domain.
filetype:	site:corp.example filetype:pdf annual report	Find public PDF reports; inspect only documents intentionally public.
intitle:	site:corp.example intitle:press release	Find pages with relevant titles.
Combined	site:corp.example filetype:pdf policy	Narrow a public search by domain and file type.

3.3 Item-to-technique and indicator mapping

Public information category	Potential misuse scenario (awareness only)	Indicator employees should notice	Recommended control
Job advertisement names tools or departments	Phishing message impersonates a recruitment or IT workflow.	Unexpected attachment, login link or request for credentials.	Verify recruitment communications through the official portal.
Annual report describes business initiatives	Pretext claims to relate to a named project or supplier.	Unusual urgency or request for confidential project data.	Verify the sender and business need through a separate channel.
Press release names executives or events Public profile describes office locations or visitor processes	Vishing caller claims to be an executive or event organizer. Tailgating pretext claims to be a visitor or contractor.	Caller pressures staff to bypass normal approval. Unknown person asks to follow an employee through a controlled door.	Call back using a trusted directory number. Challenge politely and follow visitor/badge procedures.

3.4 Test organizations and predicted human-risk levels

Synthetic test organization	Public-information profile	Predicted exposure	Evaluation question
RichInfo Ltd.	Many current job ads, annual reports and press releases.	Higher contextual exposure because multiple details can be combined.	Do the details create credible pretexts, and are they already public by design?
SparseInfo Ltd.	Minimal public documents and limited corporate announcements.	Lower discovery yield, but not zero risk.	Does low discoverability materially reduce likely human risk?
MisleadCo Ltd.	Outdated or contradictory public pages.	Risk of false assumptions and inaccurate pretexts.	Can freshness checks prevent misleading conclusions?

The highest-risk source cannot be declared universally without the actual collected items. A source is more concerning when it is current, detailed, easy to verify and reveals operational processes. In many cases, job advertisements and public profiles reveal useful context, while annual reports and press releases are intentionally public and require careful interpretation.

3.5 Additive improvements

- Add public procurement/tender notices as a source category, subject to the same public-only and scope rules.
- Add a verification awareness control: employees independently confirm sensitive requests using a known directory or approved ticketing channel.
- Add a freshness score and source-confidence field so outdated or misleading items are not treated as current facts.

Q4 – Design a Reconnaissance Data-Validation Mechanism

4.1 Validation model

Every collected item passes through ordered checks before it can be used in an assessment. A rejected item is not used; a recoverable item is held for confirmation or re-query; a valid item is retained with provenance.

Check	Question	Valid / recoverable / reject rule
Scope	Is the exact domain, host, document or service authorized?	Out of scope: reject. Ambiguous ownership: hold for confirmation.
Freshness	Is the observation current enough for the assessment?	Old or unknown date: re-query or mark historical.
Duplication	Is the same normalized observation already stored?	Duplicate: merge provenance rather than count twice.
Reliability	Is the source authoritative, direct and reproducible?	Weak source: corroborate; unverifiable item: reject.
Completeness	Are required fields and collection context present?	Missing query/time/source: recover if possible, otherwise reject.

4.2 Recommended validation order

- Scope gate first: immediately reject out-of-scope items before spending effort on them.
- Required-field and format check: ensure source, query, timestamp and target are present.
- Deduplicate normalized items to avoid repeated downstream checks.
- Check freshness and re-query recoverable stale items.

- Assess source reliability and corroborate high-impact observations.
- Assign final status and preserve the reason for each decision.

4.3 Five test sequences and predicted outcomes

Sequence	Input pattern	Predicted outcome	Reason
A – all valid	In-scope, current, unique, authoritative items.	All pass.	Every required validation condition is met.
B – out of scope	One item refers to an unapproved third-party domain.	Reject that item immediately.	Scope is a hard boundary.
C – stale data	A record is old and conflicts with the current authoritative response.	Re-check; retain only after confirmation.	Freshness problem may be recoverable.
D – duplicate data	Same normalized DNS observation appears from two collection runs.	Merge / deduplicate.	One fact should not be counted twice.
E – weak source	An unattributed search snippet claims a host exists.	Re-check or reject if not corroborated.	A search snippet alone is insufficient proof.

These are predicted test outcomes, not measured results. To complete the experiment, enter the actual input count and observed valid, rejected and re-check counts after running the validation implementation.

4.4 Scaling from one to fifty targets

At one target, manual review is practical. At fifty targets, a structured pipeline is preferable: normalize domain names, apply an allow-list, deduplicate by a stable key,

cache only within a documented freshness window, and route ambiguous or high-impact findings to a human reviewer. Scope rejection should remain the earliest gate so scale does not increase accidental third-party collection.

Measure	One target	Fifty targets – design expectation

Scope checks	Manual allow-list comparison is manageable.	Automated allow-list gate plus exception review.
Duplicate handling	Manual comparison may suffice.	Normalized keys and deduplication required.
Freshness	Review each observation.	Use timestamp/TTL policy and scheduled re-query.
Reliability	Manual source assessment.	Source scoring plus human review for high-impact items.
Auditability	Single collection log.	Centralized append-only logs and per-target provenance.

Q5 – Evaluate Footprinting of a Hierarchical Organization

5.1 Representation and traversal

Represent the footprint as a rooted tree. The root is the authorized parent domain; child nodes are approved subdomains; leaf nodes may be departments or services. A node is traversed only if it remains inside the approved boundary. A node with no public data is recorded as an empty/terminal node rather than treated as an error.

```
TRAVERSE(node):
  if node is outside approved_scope: return
  record(node)
  if node is terminal or has no approved children: return
  for child in approved_children(node):
      TRAVERSE(child)
```

5.2 Example synthetic hierarchy

Level	Synthetic node	Children / status	Boundary decision
0	corp.example	Root domain; authorized.	Traverse.
1	www.corp.example	Public website.	Traverse.
1	mail.corp.example	Mail service record.	Record; do not probe service unless separately authorized.
1	research.corp.example	Department subdomain.	Traverse if listed in scope.
2	portal.research.corp.ex ample	Approved public portal.	Record.
2	archive.research.corp.e xample	No public data returned.	Record empty/terminal; stop branch.
1	vendor.example	Third-party provider.	Out of scope unless separately authorized; stop.

5.3 Contrasting tree shapes

Structure	Shape characteristics	Expected traversal impact
Shallow	Few levels and broad branches.	Low recursion depth; possibly many sibling nodes.
Deeply nested	Long chain of subdomains and services.	More depth and boundary checks; recursion or stack limits matter.

Irregular	Branches differ in depth and size; some empty.	Requires explicit handling of missing children and terminal nodes.

For a tree with N in-scope nodes, a correct traversal visits each eligible node once, giving O(N) time and O(H) recursion space for height H (or O(N) storage if a visited set and full output are retained). A depth limit and visited set can protect against malformed or cyclic input data. DNS itself is not a tree in every operational sense; this representation is a planning model for authorized asset relationships.

5.4 Prediction, boundary and correctness checks

- Before traversal, count expected nodes from the synthetic inventory and predict which branches are empty or out of scope.
- After traversal, compare visited in-scope nodes with the inventory; calculate coverage as visited eligible nodes divided by total eligible nodes.
- Verify that no out-of-scope node is queried or expanded.
- Verify that an empty branch is recorded and traversal continues with its siblings.
- Compare with ad-hoc collection: structured traversal improves repeatability and coverage accounting; ad-hoc browsing may be faster for a tiny target but is harder to audit.

Actual node counts and coverage percentages should be calculated from the student's implemented test tree. No measured counts are invented here.

Q6 – Evaluate Footprinting Approaches Under Constraints

6.1 Approaches

Approach	What it produces	Strengths	Limitations
Passive OSINT	Public registration data, indexed pages, archived pages and public	Low direct interaction with target services; useful for context	Incomplete indexing, stale information and source bias.

	documents.	and broad discovery.	
Active DNS/service footprinting	Directly queried DNS records and, where approved, permitted service metadata.	More current technical observations and clearer resolver-level evidence.	Creates traffic, may be logged, requires strict authorization and rate control.

6.2 Comparison plan for increasing scope sizes

Use the same authorized target inventory for both approaches. Suggested test sizes are 1, 5, 20 and 50 approved names. At each size, record query/step count, elapsed time, unique verified items, duplicate count, out-of-scope rejects and coverage. The sizes are a proposed test design, not completed measurements.

Scope size	Passive OSINT – expected behavior	Active DNS – expected behavior	Evidence to record
1 name	Manual search is practical; results may be sparse.	A few record queries are practical.	Queries, elapsed time, verified findings.
5 names	Repeatable with a source log.	Batch DNS queries remain manageable.	Unique items, duplicate rate, scope checks.
20 names	Search repetition and source review increase.	Automation helps; rate limits and logging matter.	Coverage, query count, error/retry count.
50 names	Manual review may become time-consuming.	Scripted queries can scale, subject to authorization and rate controls.	Time, completeness, duplicates, failures, human-review effort.

6.3 Redundancy and recommendation

Passive collection can repeat the same indexed document across multiple search queries; active collection can repeat identical DNS lookups across runs or resolvers. Deduplication should preserve all source references while counting the underlying fact once. The fastest approach is not always best: passive collection may be quieter but incomplete; active DNS may be more direct but creates observable traffic. For a small-scope engagement, begin with passive OSINT and add narrowly targeted DNS checks. For a large-scope engagement, use a hybrid workflow with automated, rate-limited DNS collection and passive context gathering, followed by human validation.

For teaching, the passive workflow is useful for source criticism and provenance; controlled DNS labs are useful for record interpretation and repeatable experiments. For a real assessment, authorization, scope compliance and evidence quality take precedence over speed or stealth.

Q7 – Integrated Review: Diagnose, Redesign and Defend

7.1 Selected workflow and limitation

Selected workflow: Q4 reconnaissance data validation. A common limitation in an unstructured workflow is that analysts investigate freshness and source reliability before checking whether an item is in scope. This wastes effort and creates a risk of processing third-party data that was never authorized. This is a design diagnosis to be tested, not a claim that an experiment has already demonstrated a measured failure.

7.2 Evaluation criteria

Criterion	Definition / measurement
Scope compliance	Number of out-of-scope items processed

	beyond the initial gate; target is zero.
Validation effort	Number of checks performed across all input items.
Data quality	Valid unique items retained divided by all retained items.
Recovery efficiency	Recoverable items correctly routed for confirmation rather than silently accepted or discarded.
Auditability	Percentage of retained/rejected items with source, timestamp and reason recorded.

7.3 Redesigned workflow

- Normalize the item and identify its target.
- Apply the exact authorization allow-list; reject out-of-scope items immediately.
- Check mandatory provenance fields and deduplicate.
- Check freshness; send stale but potentially useful items to re-query.
- Assess source reliability and corroborate important findings.
- Record final status, decision reason and evidence reference.

Trade-off: the scope-first gate reduces unnecessary processing and boundary risk, but depends on a complete, maintained allow-list. Ambiguous ownership must be escalated rather than automatically included.

7.4 Before-and-after validation plan

Test input	Original order (proposed baseline)	Redesigned order (expected)	Metric
Out-of-scope item with strong source	May undergo source/freshness review before	Rejected at first gate.	Checks performed before rejection.

	scope rejection.		
In-scope stale item	Freshness check flags re-query.	Passes scope gate, then routed to re-query.	Correct recovery status.
Duplicate valid item	May be re-checked more than once.	Deduplicated before expensive checks.	Repeated checks avoided.
In-scope weak-source item	Reliability check flags corroboration.	Same reliability outcome after scope gate.	Decision quality retained.

Run both versions against the same synthetic input set and record actual counts of checks, time, valid items, rejected items and re-checks. The redesign is successful if it reduces unnecessary checks and keeps out-of-scope items at zero without reducing valid-item retention. Do not claim numerical improvement until the test has been executed.

7.5 Final engineering judgment

The redesigned scope-first workflow is preferable for repeatable assessments because it enforces authorization before analysis and reduces wasted work. The original order may still be acceptable for a tiny, manually curated dataset where scope is already guaranteed by the collection process. For larger or mixed-source datasets, an explicit early scope gate, deduplication and provenance logging provide stronger control and auditability.

Implementation and Evidence Checklist

● Attach written authorization and the exact allow-list used for every practical test. ● Include raw WHOIS/RDAP, dig and nslookup outputs with timestamps and resolver details.

● Include the exact search operators and URLs for public-source observations.

- Show the synthetic test data and prediction-versus-observation tables.
- Include the validation and traversal pseudocode or scripts.
- Record actual query counts, node counts, pass/fail/re-check totals and timings only after execution.
- Redact personal data and secrets; do not include credentials, private records or information collected outside scope.

Conclusion

A dependable footprinting programme is not simply a collection of commands. It is an authorized, evidence-led process that combines multiple sources, validates provenance and freshness, interprets DNS carefully, models organizational relationships, and adapts its collection method to scope and constraints. The strongest engineering design is repeatable, auditable, rate-limited and explicit about uncertainty. The report provides the workflow and test plan; practical evidence must be added from the student's own authorized lab execution.

References

- ICANN. Registration Data Access Protocol (RDAP) and registration data guidance. https://www.icann.org/rdap
- Internet Systems Consortium. BIND 9 Administrator Reference Manual – DNS and zone transfer configuration. https://bind9.readthedocs.io/
- RFC 1034. Domain Names – Concepts and Facilities. https://www.rfc-editor.org/rfc/rfc1034
- RFC 1035. Domain Names – Implementation and Specification. https://www.rfc-editor.org/rfc/rfc1035
- RFC 5936. DNS Zone Transfer Protocol (AXFR). https://www.rfc-editor.org/rfc/rfc5936
- OWASP. Web Security Testing Guide – Information Gathering. https://owasp.org/www-project-web-security-testing-guide/
- MITRE ATT&CK. Reconnaissance (TA0043). https://attack.mitre.org/tactics/TA0043/

- CISA. Avoiding Social Engineering and Phishing Attacks. https://www.cisa.gov/secure-our-world/recognize-and-report-phishing